

AdvocateAuroraHealth

Title: AAH Cybersecurity Incident Response		Document Number: 2473
Document Type: ☒ Policy ☐ Procedure ☐ Guideline ☐ Other		Last Review/Revision Date: 06/29/2021
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date: 06/29/2024
		Effective Date: 06/29/2021
Scope: ☒ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name):		

I. PURPOSE

This policy governs the actions required for reporting or responding to cybersecurity incidents involving Advocate Aurora Information and/or Information Resources to ensure effective and consistent reporting and handling of such events.

II. SCOPE

This Policy applies to all Advocate Aurora information and information resources of Advocate Aurora Health and any entity or facility owned and controlled by Advocate Aurora.

III. DEFINITIONS/ABBREVIATIONS

Advocate Aurora Team Member: anyone employed by Advocate Aurora Health Care who provides services on behalf of Advocate Aurora. All Advocate Aurora Team Members are expected to abide by Advocate Aurora policies and procedures. All Advocate Aurora Team Members are eligible to receive access to internal Advocate Aurora systems, as required.

Advocate Aurora Information: All information that is owned by Advocate Aurora or owned by third parties but provided to Advocate Aurora. For clarification purposes only, information remains "Advocate Aurora Information" even if it is in the possession and under the control of a third party (e.g., a third party service provider and/or its subcontractors).

Advocate Aurora Information Resources: Any media, software, hardware or other technology that supports the use, access, processing, storage or transmission of Advocate Aurora Information.

Cybersecurity Incident: Any real or suspected event that may adversely affect the security of Advocate Aurora information or the systems that process, store, or transmit that information. Examples include:

- Unauthorized access to Advocate Aurora Information or Information Resources
- Loss or theft of Advocate Aurora Information or Information Resources
- Computer infected with malware such as a worm, virus, Trojan Horse, ransomware or botnet
- Unauthorized reconnaissance activities such as scanning the network for security vulnerabilities
- Denial of Service attack
- Web site defacement
- Unauthorized exfiltration of data
- Violation of an Advocate Aurora policy

Cybersecurity Incident Response Team (CSIRT): The CSIRT is a group of leaders from various areas of the organization who work together to identify, contain, eradicate and recover from serious Cybersecurity incidents.

IT Support Personnel: Team Members whose duties include supporting and maintaining Advocate Aurora Information Resources.

Security Event: An observable occurrence in an Information Resource indicating that a security policy may have been violated or a security safeguard may have failed.

Security Operations Center (SOC): A division of HIT which manages security issues on an organizational and technical level.

IV. **POLICY**

- A. Advocate Aurora must create and maintain an Information Security Incident Response Plan and Team Members must follow the plan accordingly when there is a Cybersecurity Incident.
- B. Team Members should report any suspected phishing email or any security event that may cause disruptions to important business processes as soon as possible.
 1. Team Members must err on the side of caution and report *any* issues with the performance of an AAH Information Resource to the Service Desk.

2. Individual Team Members must not pay ransomware to recover any AAH Information Resource.
 3. To avoid inadvertent violations of state or federal law, individual Team Members or departments may not release any AAH Information and/or Information Resources to any outside entity, including law enforcement organizations, before making the notifications as designated in the Cybersecurity Incident Response plan.
 4. When a security event is analyzed and deemed critical, the SOC will notify IT Security Leadership who will make the decision to invoke the CSIRT process.
 5. Team Members working on Information Security Incidents must not discuss the incident with anyone who is not part of the Information Security Incident Response Team, unless directed to by the incident manager.
- C. Team Members connected with a Cybersecurity Incident must cooperate with and assist the SOC with their investigation according to the Cybersecurity Incident Response Plan.
- D. Records must be kept for at least 6 years on incidents involving unauthorized disclosure of PHI to meet HIPAA regulatory requirements.
- E. AAH Information continues to be owned by AAH regardless of how or where it is stored, processed or transmitted. Reporting requirements of this policy apply to third parties that are contractually bound to limit the access, use or disclosure of AAH Information Resources. These third-party vendors or entities shall report potential or actual incidents to AAH per the terms of their contract and/or AAH policies.
- F. Notification
1. Team Members who discover a Security Event (e.g. a suspicious email, an Information Resource not functioning appropriately, or a notification from a vendor of a known security issue) must report it to the appropriate IT support personnel or the Advocate Aurora IT Service Desk
 2. Team Members who become aware of loss or theft of

an AAH computing device or media must report the loss or theft to Loss Prevention immediately.

3. IT Support Personnel or the AAH IT Service Desk must create a ticket for the SOC.
4. The SOC will initiate an investigation after notification of a Security Event, as appropriate.
5. The CSIRT is responsible for notifying regulatory bodies in the event of an incident or breach. CSIRT is also responsible for notification to affected individuals, if legally necessary.

G. Information Security Investigation

1. The SOC will manage the investigation process and follow the Cybersecurity Incident Response Plan.
2. The SOC shall maintain documentation on the preservation of evidence during the course of the investigation.
3. The SOC shall have the ability to conduct forensic investigations. An external vendor may be used for this purpose.

H. Containment

1. If a Cybersecurity Incident could spread to additional systems (e.g., involves credentials with administrative access to multiple devices, the threat is determined to be a worm, etc.) then personnel must assist in containment, including, but not limited to:
 - a) Providing forensic images (memory and disk)
 - b) Baseline information as deemed necessary by the SOC.

I. Eradication and Recovery

1. After providing requested information to the SOC, IT will attempt to re-image the affected system(s) and restore the system(s) to service.
2. If eradication is unsuccessful, or the incident persists after re-imaging, Team Members must notify the SOC and await further instructions.

J. Resolution

1. The SOC will communicate resolution and lessons learned to Team Members, as appropriate.

V. **PROCEDURE**

Not Applicable

VI. **CROSS REFERENCES**

Information Security
Policy Information
Classifications Policy

VII. **RESOURCES AND REFERENCES**

HIPAA	164.308(a)(1)(ii)(D) – Information System Activity Review -- R 164.308(a)(6)(ii) – Response & Reporting – R 164.308(a)(7)
NIST-800-53 rev. 4	IR-1 through IR-10
PCI DSS 3.2.1	12.5.3, 12.10.1, 12.10.5, 12.10.4 & 12.10.6.
HITRUST CSF v.8.1	11.a-11.e
CIS Critical Security Controls	CSC #19 Incident Response and Management

VIII. **ATTACHMENTS**

Not Applicable